

Finding 02 — Weak SSH Credentials

Penetration Testing Finding Report

Target	Metasploitable 2
Target IP	192.168.116.129
Port	22/TCP
Service	SSH
Version	OpenSSH 4.7p1 Debian 8ubuntu1
Finding	Weak / Default SSH Credentials
CVE	Not applicable
Severity	High
Assessment Type	Authorized lab / educational assessment

Executive Summary

During an authorized penetration-testing exercise against the Metasploitable 2 lab, SSH was identified on TCP port 22. Credential testing against the lab target successfully identified the credential pair **msfadmin:msfadmin**, and the supplied evidence shows that the credentials were accepted and an SSH session was opened. This demonstrates that the account is protected by a weak/default credential that can be recovered through credential testing.

1. Discovery

Nmap identified the SSH service as:

```
22/tcp open ssh OpenSSH 4.7p1 Debian 8ubuntu1
```

The version and exposed SSH service were recorded as part of the initial service enumeration.

2. Credential Testing

Credential testing was performed against the authorized Metasploitable 2 laboratory target. The test successfully identified:

```
Username: msfadmin
Password: msfadmin
```

The supplied Metasploit output reports a successful authentication and an opened SSH session.

3. Result

The successful authentication resulted in an SSH shell session on the target. The session information shown in the evidence identifies the remote account as **msfadmin** and the target as **192.168.116.129:22**.

4. Impact

An attacker who can discover or guess the weak credentials may authenticate directly to the SSH service. Depending on the privileges and access available to the compromised account, this can provide unauthorized access to files, services, and system resources and may become a stepping stone for further compromise.

5. Evidence

Evidence 1 — SSH Service Enumeration

```
root@kali: ~  
File Actions Edit View Help  
root@kali: ~  
zsh: corrupt history file /root/.zsh_history  
(root@kali)~  
# nmap -sC -p 22 --version-all 192.168.116.129 -A  
Starting Nmap 7.95 ( https://nmap.org ) at 2026-09-01 17:09 EEST  
Nmap scan report for 192.168.116.129  
Host is up (0.0015s latency).  
PORT      STATE SERVICE VERSION  
22/tcp    open  ssh      OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)  
| ssh-hostkey:  
|_ 1024 60:0f:cf:e1:c0:5f:6a:74:d6:90:24:fa:c4:d5:6c:cd (DSA)    
|_ 2048 56:56:24:0f:21:1d:de:a7:2b:ae:61:b1:24:3d:e8:f3 (RSA)    
MAC Address: 00:0C:29:28:09:12 (VMware)  
Warning: OSScan results may be unreliable because we could not find at least 1 open and 1 closed port  
Device type: general purpose  
Running: Linux 2.6.X  
OS CPE: cpe:/o:linux:linux_kernel:2.6  
OS details: Linux 2.6.9 - 2.6.33 (RPM kernel)  
Network Distance: 1 hop  
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel  
  
TRACEROUTE  
HOP RTT ADDRESS  
1 1.53 ms 192.168.116.129  
OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/.  
Nmap done: 1 IP address (1 host up) scanned in 8.67 seconds  
(root@kali)~  
#
```

Nmap evidence showing TCP/22 open and OpenSSH 4.7p1 Debian 8ubuntu1.

Evidence 2 — Credential Testing / Successful SSH Authentication

```
msf6 auxiliary(scanner/ssh/ssh_login) > run  
[*] 192.168.116.129:22 - Starting bruteforce  
[*] 192.168.116.129:22 - Success: 'msfadmin:msfadmin' 'uid=1000(msfadmin) gid=1000(msfadmin) groups=4(adm),20(dialout),24(cdrom),25(floppy),29(audio),30(dip),44(video),46(plugdev),107(fuse),111(lpadmin),112(admin),119(sambashare),1000(msfadmin) Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686 GNU/Linux'  
[*] SSH session 1 opened (192.168.116.128:43535 → 192.168.116.129:22) at 2026-09-01 17:18:42 +0300  
[*] Scanned 1 of 1 hosts (100% complete)  
[*] Auxiliary module execution completed  
msf6 auxiliary(scanner/ssh/ssh_login) > sessions  
  
Active sessions  
=====
```

Id	Name	Type	Information	Connection
1		shell linux	SSH root @	192.168.116.128:43535 → 192.168.116.129:22 (192.168.116.129)

```
msf6 auxiliary(scanner/ssh/ssh_login) >
```

Metasploit evidence showing the successful credential result and the opened SSH session.

6. Remediation

1. Change the default/weak password for the affected account immediately.
2. Use a long, unique password that is not reused on other systems.
3. Remove or disable default accounts when they are not required.
4. Consider SSH key-based authentication and disable password authentication where operationally appropriate.
5. Restrict SSH access with firewall rules, network segmentation, or an allowlist of trusted administration hosts.
6. Implement login monitoring and rate limiting / lockout controls appropriate to the environment.

7. CVE

Not applicable. This finding is based on weak/default authentication credentials rather than a specific software vulnerability identified by a CVE.

8. References

Metasploitable 2 laboratory environment and captured assessment evidence.

Note: The assessment was performed against a controlled lab target. Findings and severity should be reassessed before applying the same conclusions to a production environment.